# ISS-exam-24/02/2021

---

**(1) Discuss what is TLS *client authentication*, how it works, and its advantages and disadvantages.**

- **What:** It is a way to perform authentication of the client when opening the TLS channel. If the authentication fails the channel is not opened.
- **How:** TLS client authentication works by performing an explicit challenge-response authentication schema, where the server is requesting to the client to present public certificate and then to use the corresponding private key to sign an hash of the previous exchanged messages.
- **Advantages:** This is the strongest kind of authentication and also it is the best minimization of the attack surface, because if the authentication fails the channel is not opened. The server does not need for storing any password.
- **Disadvantages:** The client must have and be able to use a private and a public key (and a certificate, that is not common). This schema is slow because it requires more computation (use of asymmetric crypto) and more data exchanged during the TLS handshake. Besides, it implies everything it is related to PKI (e.g. you must trust the root certificate and especially you have to perform some kind of validation of the client certificate, for example consult a CRL).

---

**(2) Explain what is a KDF, tell which security problem it addresses, which kind of cryptographic function it is normally built upon, which input parameters it takes and explain the role/importance of each parameter.**

- **What:** KDF is a function to create a cryptographically valid key, that is normally a key that has the same probability of having zeros or ones in each bit.
- **Which security problem:** it addresses the problem of generating secure key starting from some secret known by the user (e.g. a passphrase).
- **Which kind of function:** normally, it uses, as a basic component, a cryptographic hash function.
- **Input parameters (role/importance):** The passphrase (it must be a passphrase not just a password???), the salt (in order to avoid having the same key derived from the same passphrase), the number of iterations (which is used to make the computation of dictionary more difficult for an attacker).

**(3) Explain the main characteristics of STUXNET and tell why it is considered the prototype of a new class of attacks and which are the main lessons that we should learn from it.**

- **Explain:** it was to be targeted to a specific system, that was controlling the SCADA system of the nuclear reactor and to employ various kind of attacks with disguising the attacks as a valid drive digitally signed by Microsoft.
- **Why a prototype:** Because it was the first kind of malware for cyber-physical systems. So, it's a malware that was in the cyberspace, but it was attacking a system that has effect on the real life (on the physical world).
- **Main Lessons:** even if the system is air-gapped, it needs to have proper cyber-protection. There was no internal firewall among the various components, no anti-malware, no regular updates of the system, the OS was not minimized (there was running useless services), the system was configured with the default passwords, the updates done by technician were not digitally signed, so it was possible to manipulate them and also to inject the malware.

**(4) Draw the schema of a firewall architecture of type dual-homed gateway, explain the type and role of each component, and discuss its advantages and disadvantages.**

- **Schema:** It is like a line, you start with external network, then a packet filter, then a gateway and then the internal network.
- **Explain:** The packet filter has the role of filtering the packets at the gross level, typically at IP level, something at transport level (just the ports). Then the gateway is hosting typically an application-level gateway, in order to perform better filter on those packets that have passed the first kind of control. For incoming and outgoing, you could even validate users and typical things (*in my opinion is generic, but professor said it*)
- **Advantages:** We have control and filtering at two different levels (network level as well as at application level), so we are able to perform much better analysis of the packets. We don't have a single point of failure (somehow there is defense in depth, it is really just a double defense of line because we have a single element, not two different system one after the other). We have some sort of DMZ, it is not a true DMZ.
- **Disadvantages:** There is no flexibility, all the traffic must pass through both systems. So, there could be a problem with an high throughput, if the gateway is not able to keep the pace of the packet filter.

**(5) Explain the weaknesses of DHCP, describing also which kind of attacks can be performed by exploiting those weaknesses.**

- **Explain:** The weaknesses are basically two:

  1. This is a not authenticated protocol, so you don't know if the answer is coming from the real DHCP server or not.
  2. It is a broadcast protocol, so anybody can listen to the request of the messages.

- **Attacks:** Three kind of attacks can be performed:

  - Creating denial of service by giving a wrong configuration to a DHCP client.
  - Creating a logical MITM by providing a wrong answer. In this case the wrong answer aims to create a direct connect between the client and the attacker, which act as the default gateway (giving an address with a subnet 255.255.255.252).
  - You can also alter the default name server in order to be able to change also correspondence between name and addresses.